

SSRF Attacks

CompTIA PenTest+ (PT0-003)

Domain: 4.0: Attacks and Exploits

Objective: 4.5: Given a scenario, perform web application attacks using the appropriate tools.

Video Overview

Welcome to this video on Server-Side Request Forgery (SSRF)! This video directly aligns with Exam Objective 4.5: Given a scenario, perform web application attacks using the appropriate tools. As you delve into the world of web application security, understanding SSRF is essential. This vulnerability, often leveraged by attackers, can turn a seemingly harmless web application into a powerful tool for internal network reconnaissance and data exfiltration. By exploring how SSRF works, its common attack scenarios, and practical exploitation techniques, you'll gain insights that are directly applicable to your future roles in penetration testing and cybersecurity. Recognizing and mitigating such vulnerabilities is a core skill for any professional securing digital assets in today's complex cloud environments.

Key Topics Covered

- SSRF Definition: Web application fetching remote resources without validating user-supplied URLs.
- OWASP Top 10 (2021): SSRF listed as number ten in web application security risks.
- Bypassing Security Controls: How SSRF uses the web server as an "inside man" to bypass firewalls and VPNs.
- Port Scanning Internal Servers: Exploiting SSRF to map unsegmented networks by identifying open/closed ports.
- Sensitive Data Exposure: Accessing local files (e.g., /etc/passwd) and cloud storage metadata via SSRF.
- URL Manipulation for Exploitation: Modifying URL parameters to perform port scans and read local files.
- Automated Exploitation: Using tools like Burp Suite Intruder for efficient SSRF vulnerability testing.

Student Notes Section